INFORME DE VULNERABILIDAD DE PHP: PHP2Shell

CVE-2026-109618 y CVE-2026-109619: descripción y parche aplicado en pnkSecurity

Fecha de emisión del informe	26/10/2026
Responsables	Savka Carvajal · Matías Nonque
Versión del informe	1.0 (complemento del Informe de remediación v2.2)
Clasificación del documento	Confidencial
Repositorio	https://github.com/matiasNon/pnkSecurity — rama mejoras-por-vul
Servidor AWS (revisión)	https://3.230.214.61/index.php?id=1 (certificado autofirmado)
Versión de PHP tras el parche	8.5.12 en el equipo local y en el servidor AWS (incluye el parche de ambas CVE)

1. Resumen ejecutivo

El 21/10/2026 el proyecto PHP publicó una actualización de seguridad de emergencia para dos fallas críticas del propio intérprete, conocidas como **PHP2Shell**: CVE-2026-109618 y CVE-2026-109619. Ambas permiten ejecución remota de código (RCE) y tienen un puntaje CVSS v4.0 de **9,2**. El defecto no está en el código de la aplicación sino en el motor de PHP, por lo que las correcciones de código de las 12 vulnerabilidades del Informe de remediación (consultas preparadas, escape de salida, CSRF, etc.) **no la mitigan**: la única corrección completa es actualizar PHP.

pnkSecurity se ejecuta sobre PHP, y el despliegue de AWS usa Apache con mod_php, que es la configuración que el propio proyecto PHP señala como la más expuesta. Este informe describe la vulnerabilidad, su efecto sobre el proyecto y el parche. **Estado:** el entorno local ya fue actualizado de PHP 8.3.35 a **8.5.12** y verificado, y el servidor de AWS (Ubuntu 24.04, Apache con mod_php) fue actualizado a **PHP 8.5.12** el 26/10/2026 y verificado desde fuera: la aplicación responde con normalidad y supera las pruebas del proyecto (PASS=73, FAIL=0). Después, el equipo eliminó del servidor los paquetes de PHP 8.3 que habían quedado instalados pero desactivados (sección 6).

2. Descripción de la vulnerabilidad

Fuente principal: The PHP Foundation (aviso del 21/10/2026). Las dos fallas son errores de gestión de memoria que se disparan cuando una petición termina de forma anormal (por ejemplo, al alcanzar memory_limit) y dejan el estado interno de PHP dañado.

	CVE-2026-109618	**CVE-2026-109619**
Aviso (GHSA)	GHSA-w8hw-w9fx-j79w	GHSA-6wmf-4rv5-p3rp
Severidad	CVSS v4.0 9,2 (crítica)	CVSS v4.0 9,2 (crítica)
Causa raíz	Corrupción de memoria por falta de memoria (OOM): si una petición alcanza memory_limit en un momento preciso, PHP deja datos internos a medio inicializar y luego los trata como válidos.	Estado global obsoleto: un error fatal en un punto concreto deja el estado interno apuntando a memoria de una petición anterior; otra petición del mismo proceso puede usar esa memoria ya liberada (use-after-free).

Efecto	RCE. Con Apache + mod_php, una petición sin autenticación puede dispararla antes de que se ejecute cualquier código de la aplicación; demostrada con configuración por defecto. También confirmada en PHP-FPM a través de rutas de código de la aplicación.	Use-after-free y caída del proceso; RCE demostrado contra una aplicación real con Apache + mod_php.
Corregida en	PHP 8.5.12, 8.4.27, 8.3.36 y 8.2.35	PHP 8.5.12, 8.4.27, 8.3.36 y 8.2.35

- **Qué NO es:** el puntaje oficial es 9,2. Circuló un 10,0 en reportes filtrados antes de la publicación; no es el oficial.
- **Línea de tiempo:** filtración del embargo el 20/10; publicación del parche el 21/10. Las fuentes discrepan sobre si hubo explotación activa antes del parche, por lo que se trata como riesgo real, sin afirmar un incidente.
- **Análisis independiente (Sansec):** caracteriza la primera falla como un use-after-free en el deserializador de upload_progress y la segunda como una confusión de tipos con OPcache; afirma que el código vulnerable viene desde PHP 5.4 y que todos los disparadores conocidos son peticiones multipart/form-data. Son detalles técnicos complementarios de un tercero; la descripción oficial es la del PHP Foundation.
- **Versiones sin parche upstream:** las ramas 8.0, 8.1 y anteriores no tienen versión corregida del proyecto; solo hay parches de las distribuciones (por ejemplo Debian/Ubuntu para 8.1). PHP 7.4 y 8.0 ya no reciben soporte de seguridad.

3. Efecto sobre pnkSecurity

Elemento	Situación antes del parche	Evaluación
Entorno local de laboratorio (C:\php)	PHP 8.3.35 (compilado el 22/09/2026), anterior al parche.	Vulnerable.
Servidor AWS (EC2 Ubuntu)	Ubuntu 24.04 «noble» con Apache 2.4.58 y libapache2-mod-php (instalados con el script de despliegue local deploy/aws/user-data.sh, que no se publica en GitHub), con PHP 8.3 de la distribución. La versión exacta del paquete no quedó registrada antes del cambio y la instancia tenía actualizaciones pendientes.	Configuración más expuesta (mod_php); se asume vulnerable hasta el cambio del 26/10/2026 (18:20 UTC). Ahora en PHP 8.5.12.
Aplicación	No hay formularios con archivos ni multipart/form-data (login, comentarios y carrito usan application/x-www-form-urlencoded). El fallo se dispara antes del código de la aplicación.	La ausencia de subidas no elimina el riesgo; sí permite el bloqueo temporal de la sección 4.4 sin costo funcional.

Clasificación:

- **OWASP Top 10:2025:** A03 Software Supply Chain Failures (componente de terceros vulnerable, como VUL-12).
- **ASVS v5:** V15 Codificación segura y arquitectura (gestión de dependencias y componentes).
- **ISO/IEC 27001:2022:** A.8.8 Gestión de vulnerabilidades técnicas.
- **Severidad para el proyecto:** CRÍTICA hasta aplicar el parche; mitigada con la actualización del servidor de AWS el 26/10/2026.

Este hallazgo coincide con la fila V15 del Informe de remediación, que ya marcaba «PARCIAL: falta revisión periódica de CVE de las demás librerías». PHP2Shell es un ejemplo concreto de ese punto.

4. Cómo lo parchamos

4.1 Elección de la versión

Se eligió **PHP 8.5.12**, la última versión estable publicada, que incluye el parche de ambas CVE. La rama 8.5 ya figuraba entre las versiones con las que se probó la aplicación (README). La corrección mínima habría sido PHP 8.3.36 (misma rama que se usaba antes); de hecho el 26/10/2026 se instaló primero esa versión y, a pedido del equipo, se subió después a 8.5.12. Ambas versiones corrigen PHP2Shell; en este informe queda como estado final del entorno local la 8.5.12.

4.2 Entorno local (aplicado el 26/10/2026)

Paso	Detalle	Resultado
1. Descarga	Compilación oficial php-8.5.12-1-nts-Win32-vs17-x64.zip desde downloads.php.net (la compilación vigente de 8.5.12).	Descargado (36 MB).
2. Integridad	SHA256 calculado = SHA256 del listado oficial: 2a36a2edcb7a5b9252f638fd5e4cf84d7f6e066092654220dc0b63e5cf4e9723	Coincide (Figura PHP-2).
3. Respaldos	Copia completa de C:\php antes de cada cambio: C:\php-8.3.35-backup (original, vulnerable) y C:\php-8.3.36-backup (paso intermedio).	Respaldos verificados (Figuras PHP-1 y PHP-3).
4. Actualización	Se reemplazaron los archivos de PHP y la carpeta ext por los de 8.5.12, conservando el php.ini propio.	Sin errores.
5. Ajuste de php.ini	Se comentaron session.sid_length = 26 y session.sid_bits_per_character = 5: obsoletas desde PHP 8.4 y generaban avisos al arrancar. Son los valores por defecto, así que no cambia el comportamiento.	Sin avisos (Figura PHP-5).
6. Versión	php -v	PHP 8.5.12 (cli) (built: Oct 26 2026 09:51:07), Zend Engine v4.5.12 (Figura PHP-4).
7. Extensiones	php -m	mbstring y mysqli cargadas.
8. Sintaxis	php -l sobre los 7 archivos PHP de la aplicación.	0 errores (Figura PHP-5).

Alcance de la prueba local: no se ejecutó la aplicación completa en el equipo de trabajo, porque la base de datos local exige una clave que no forma parte del proyecto. La verificación funcional completa se hace en AWS (sección 5).

Marcha atrás: borrar C:\php y renombrar el respaldo elegido (C:\php-8.3.36-backup o C:\php-8.3.35-backup) a C:\php.

Evidencias del cambio de versión

Capturas de la consola con la salida real de cada comando, generadas el 26/10/2026 en el equipo de trabajo (archivos originales en docs/evidencias-php/). En las figuras PHP-2 y PHP-5 el comando se muestra abreviado.

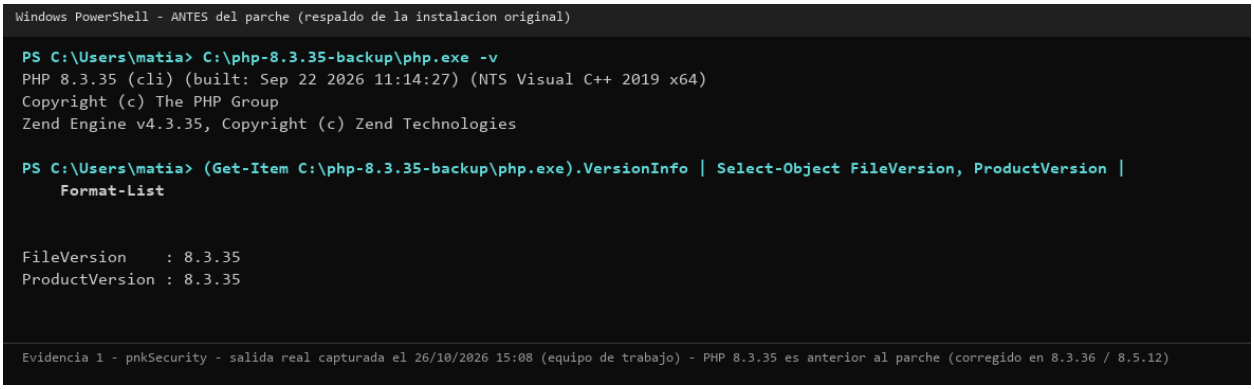


Figura PHP-1 — Antes: PHP 8.3.35 (anterior al parche), según el respaldo de la instalación original.

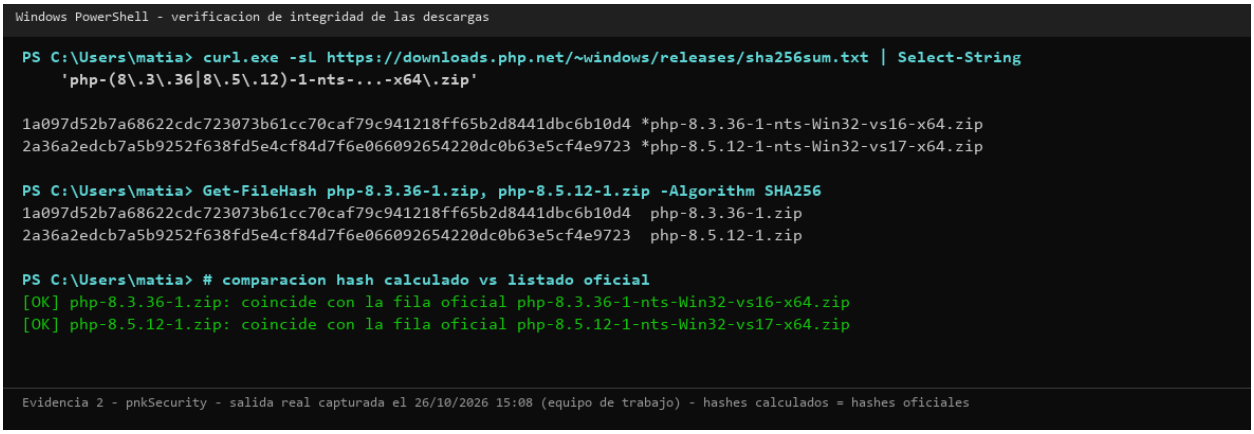


Figura PHP-2 — Integridad: los SHA256 de los zip descargados coinciden con el listado oficial de downloads.php.net.

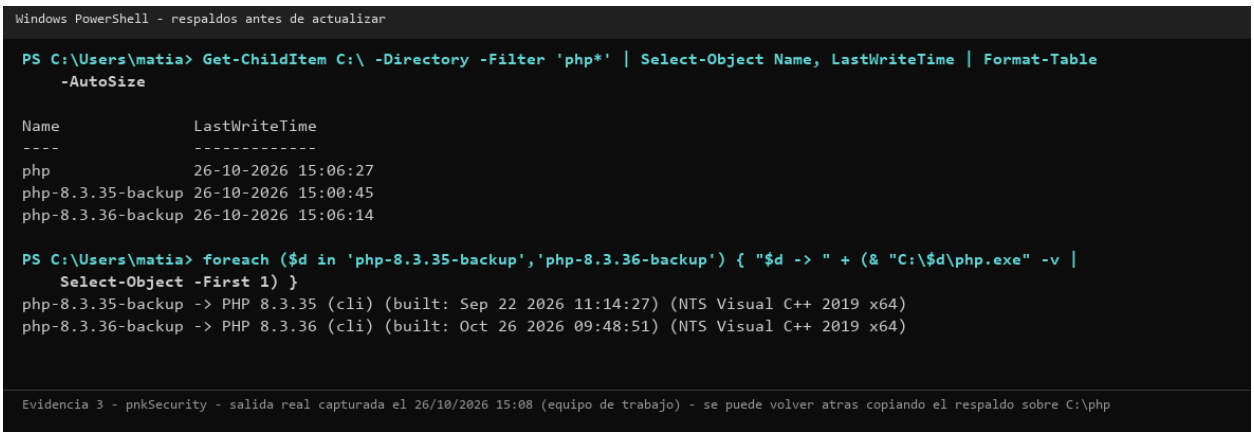


Figura PHP-3 — Respaldos de 8.3.35 y 8.3.36 creados antes de actualizar.

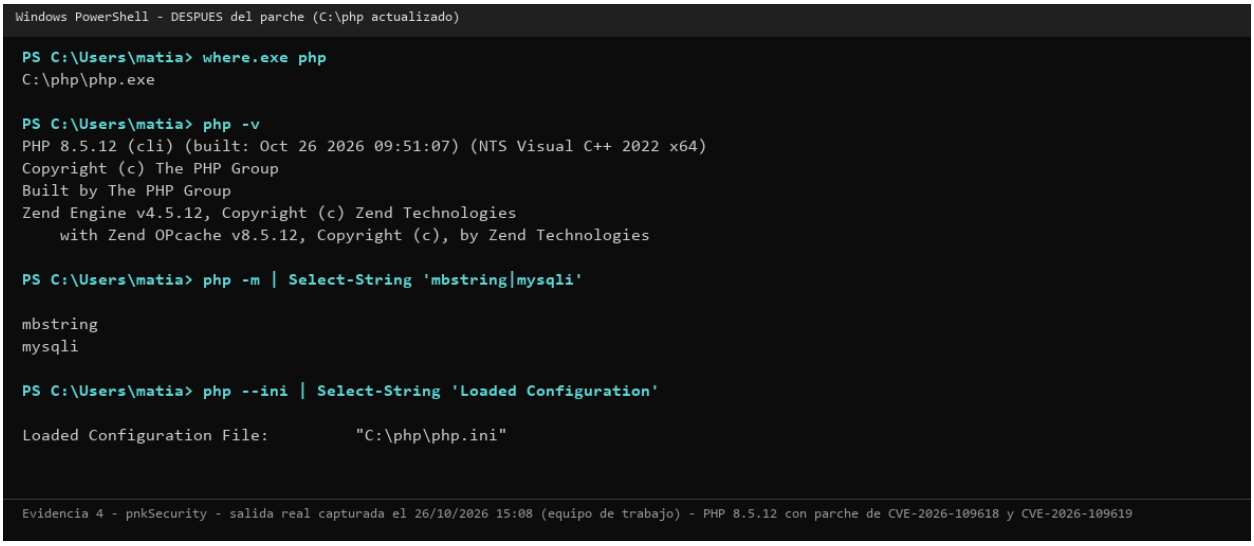


Figura PHP-4 — Después: PHP 8.5.12 en C:\php, con mbstring y mysqli cargadas y el php.ini original.

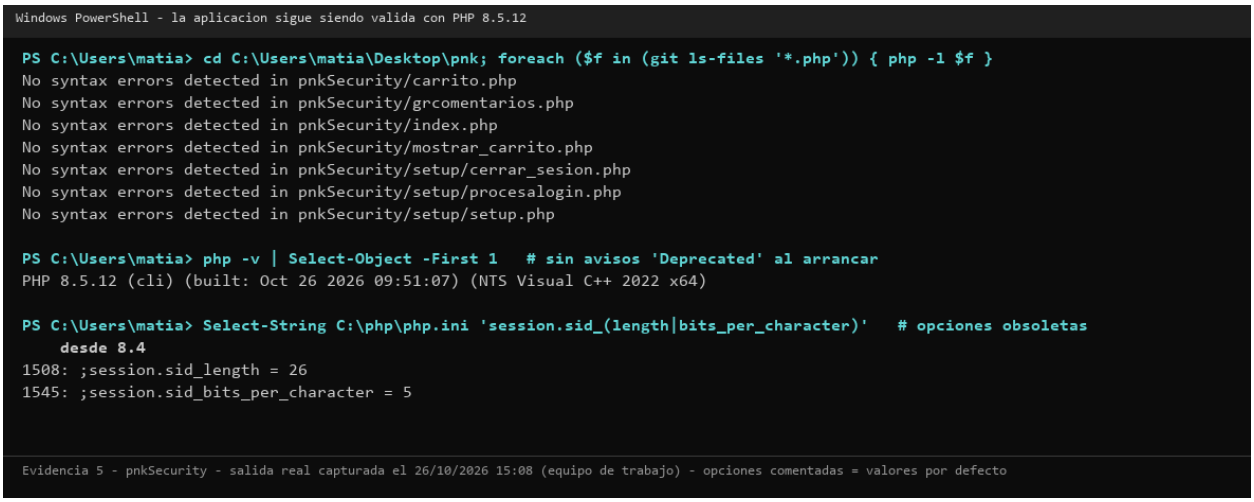


Figura PHP-5 — La aplicación sigue siendo válida con 8.5.12 (7 archivos sin errores de sintaxis) y sin avisos al arrancar.

4.3 Servidor AWS (aplicado el 26/10/2026)

El equipo aplicó la **opción de PHP 8.5.12 desde el PPA de Ondřej Surý** por SSH en la instancia EC2 (Ubuntu 24.04 «noble», Apache 2.4.58 con mod_php) y reinició Apache a las **18:20:12 UTC del 26/10/2026**. En Ubuntu el número de versión de los paquetes de la distribución no sirve para comprobar el parche; aquí se instaló directamente la versión corregida del proyecto PHP, por lo que php -v es una prueba válida.

Paso	Comando	Resultado
1. Repositorio	sudo add-apt-repository -y ppa:ondrej/php y sudo apt-get update	PPA agregado para «noble».
2. Versión disponible	apt-cache policy php8.5	Candidate: 8.5.12-1+ubuntu24.04.1+deb.sury.org+1 (Figura PHP-6).
3. Instalación	sudo apt-get install -y php8.5 libapache2-mod-php8.5 php8.5-mysql php8.5-mbstring	15 paquetes nuevos y 5 actualizados (Figura PHP-6).
4. Módulo de Apache	sudo a2dismod php8.1 php8.3, sudo a2enmod php8.5 y sudo update-alternatives --set php	Módulo php8.3 desactivado y php8.5 activado (Figura PHP-7).

	/usr/bin/php8.5	
5. Reinicio	sudo apache2ctl configtest && sudo systemctl restart apache2	Syntax OK; Apache reiniciado a las 18:20:12 UTC (Figura PHP-7).
6. Verificación en el servidor	php -v, ls /etc/apache2/mods-enabled | grep php, curl -k https://localhost/...	PHP 8.5.12; solo php8.5.conf y php8.5.load; id=1 → 200 e inyección → 404 (Figura PHP-8).
7. Verificación externa	Peticiones HTTPS desde el equipo de trabajo y script de pruebas del proyecto	Ver sección 5 (Figura PHP-9).

Observaciones del procedimiento:

- El primer intento de instalación falló por un error de copiado (dos comandos pegados en una misma línea: «Unable to locate package php8.5-mbstringsudo»). Se repitió correctamente y no quedó nada instalado a medias.
- Los metapaquetes php y libapache2-mod-php que dejó el despliegue original ahora apuntan a 8.4 en el PPA, así que apt instaló además PHP 8.4.27 (también corregido). Su módulo **no** está activo en Apache: solo php8.5 aparece en mods-enabled.
- Los paquetes de PHP 8.3 de Ubuntu quedaron instalados pero desactivados en Apache y apt los marcó como «no requeridos». No atendían peticiones web y el equipo los eliminó después, el mismo 26/10/2026 (sección 6).
- Las advertencias de Apache sobre el certificado (autofirmado, con CA:TRUE y sin coincidencia de nombre de host) son esperables con un certificado autofirmado emitido para una IP y no están relacionadas con PHP.

Marcha atrás (solo emergencia): PHP 8.3 ya fue eliminado y no debe restaurarse (versión posiblemente vulnerable). Si 8.5 diera problemas, la alternativa corregida es PHP 8.4.27, instalado junto con 8.5 (si sigue presente): sudo a2dismod php8.5; sudo a2enmod php8.4; sudo systemctl restart apache2.

Evidencias del parche en AWS

Las figuras PHP-6 a PHP-8 reproducen, como captura de consola, extractos fieles de la salida que el equipo copió de su sesión SSH (se omiten líneas intermedias, marcadas con «[...]»). La figura PHP-9 es la salida real de comandos ejecutados desde el equipo de trabajo contra el servidor.

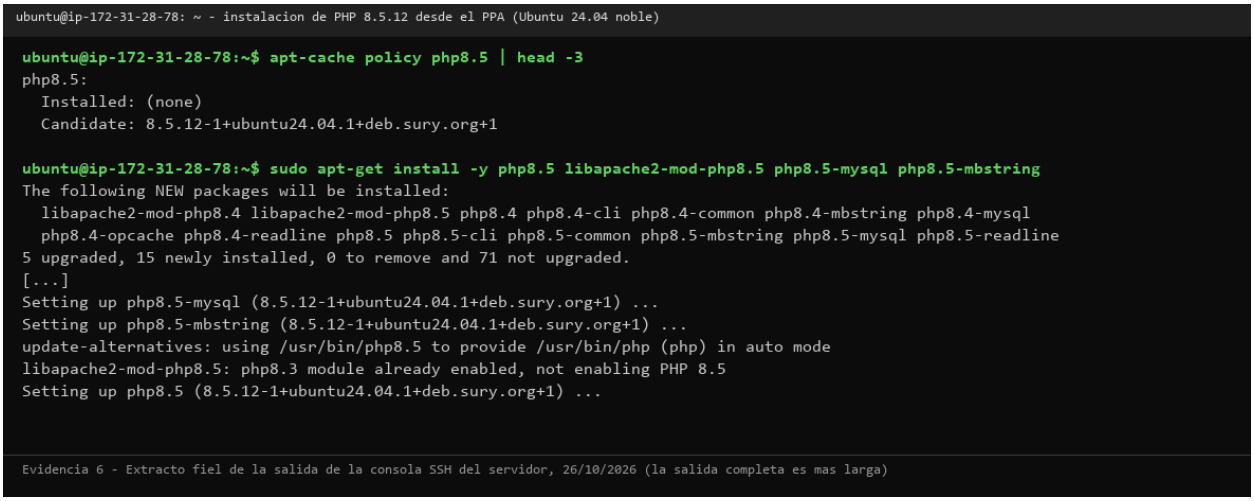


Figura PHP-6 — Instalación de PHP 8.5.12 en el servidor desde el PPA (extracto).

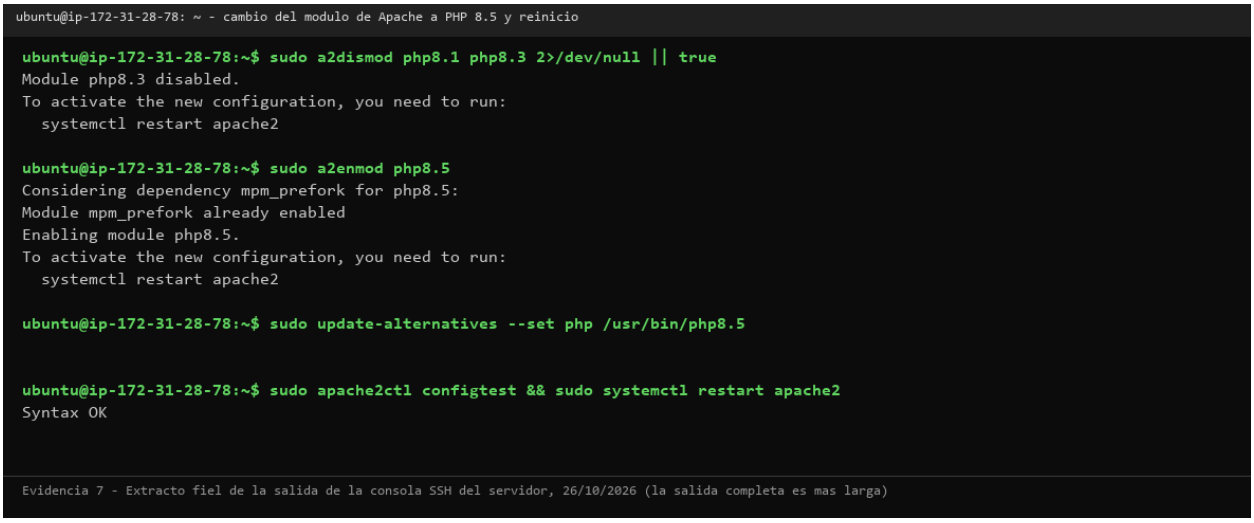


Figura PHP-7 — Cambio del módulo de Apache a PHP 8.5 y reinicio (extracto).

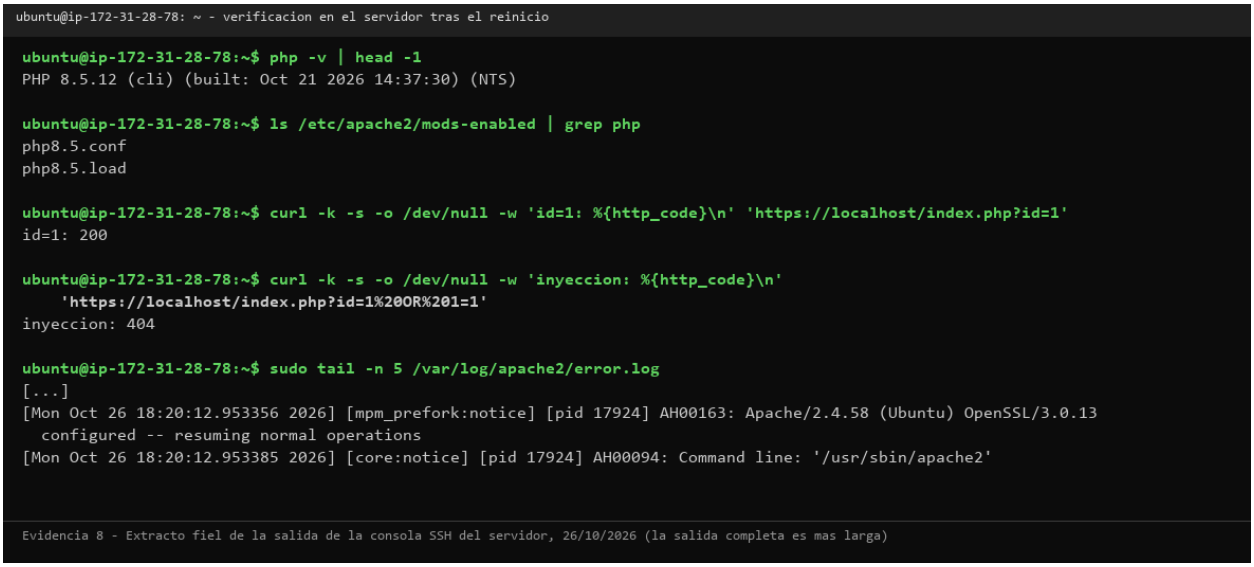


Figura PHP-8 — Verificación en el servidor: PHP 8.5.12, solo php8.5 activo, respuestas 200 y 404 (extracto).

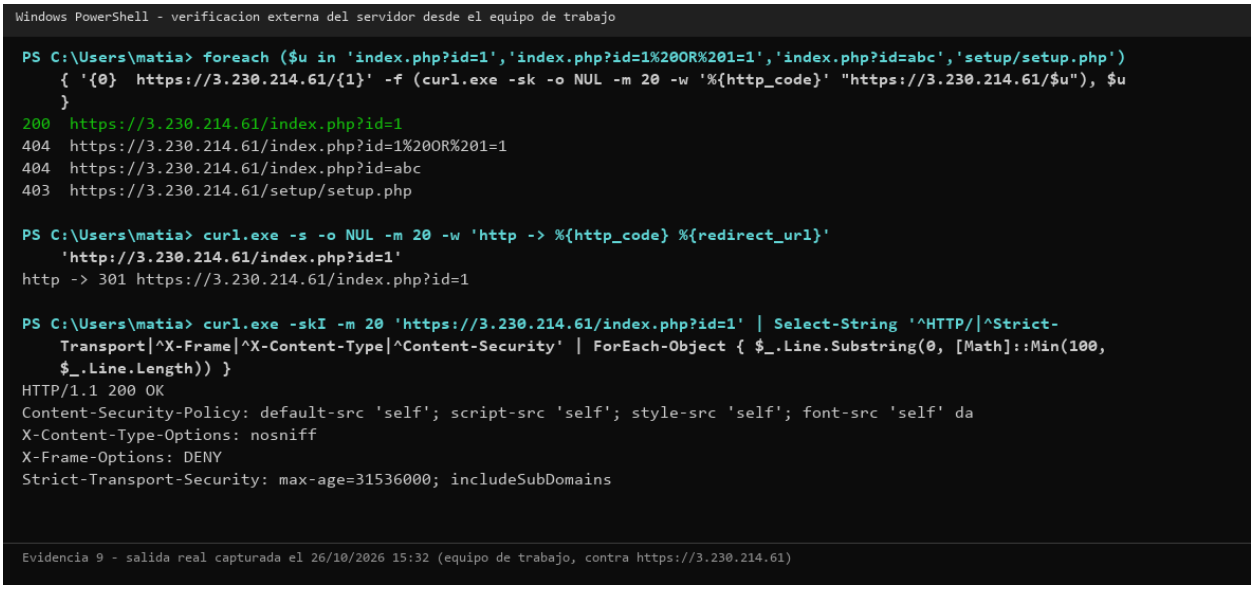


Figura PHP-9 — Verificación externa contra https://3.230.214.61: respuestas HTTP y cabeceras de seguridad, ya sin PHP 8.3 instalado.

4.4 Mitigación temporal (no aplicada; se conserva como referencia)

Como el parche definitivo se aplicó directamente, no fue necesario aplicar esta mitigación. Según el análisis de Sansec, todos los disparadores conocidos son peticiones multipart/form-data; como pnkSecurity no recibe archivos, podría rechazarse ese tipo de petición sin romper ninguna función. **No reemplaza la actualización.**

```
# dentro de <VirtualHost *:443> y <VirtualHost *:80> en /etc/apache2/sites-available/pnk.conf
RewriteEngine On
RewriteCond %{HTTP:Content-Type} ^multipart/form-data [NC]
RewriteRule ^ - [F]
```

- **No se adopta** la sugerencia de poner memory_limit en -1: en una instancia pequeña (t3.micro) una sola petición podría agotar toda la memoria del servidor.

5. Verificación y estado

Comprobación	Cómo	Estado
PHP local en 8.5.12	php -v en el equipo de trabajo (Figura PHP-4)	Aplicado y verificado (26/10/2026)
Aplicación sin errores de sintaxis	php -l en 7 archivos con PHP 8.5.12 (Figura PHP-5)	Verificado (0 errores)
PHP del servidor AWS parchado	php -v = 8.5.12 y solo php8.5 activo en Apache (Figura PHP-8)	Aplicado y verificado (26/10/2026, 18:20 UTC)
Aplicación sana tras el parche en AWS	Desde fuera: index.php?id=1 → 200; id=1 OR 1=1 → 404; id=abc → 404; setup/setup.php → 403; HTTP → 301 a HTTPS (Figura PHP-9)	Verificado
Pruebas de las vulnerabilidades en AWS	python pruebas/probar_vulnerabilidades.py https://3.230.214.61 --insecure --sin-fuerza-bruta (script local, no publicado en GitHub): **PASS=73, FAIL=0, OMITIDAS=6**,	Verificado

	ejecutado el 26/10/2026 a las 15:23 (hora local), con PHP 8.5.12 ya activo. Una repetición posterior dio login=bloqueado en las pruebas de login: la protección contra fuerza bruta de la propia aplicación (VUL-10) bloqueó la IP del equipo de trabajo tras varias ejecuciones seguidas (cada ejecución hace 5 intentos fallidos a propósito). Es el comportamiento esperado y no un fallo de PHP; se repetirá cuando expire el bloqueo.	
Retiro de paquetes PHP 8.3 sobrantes	Eliminados por el equipo en el servidor (sin salida de consola adjunta). Tras el retiro, la web sigue respondiendo igual desde fuera: 200, 404 y 403 (Figura PHP-9).	Aplicado (confirmado por el equipo)

Sobre las 6 pruebas omitidas: dos se omitieron a propósito para no escribir en la base de datos ni bloquear intentos de login mientras el servidor está en revisión (XSS almacenado, que publica comentarios, y bloqueo por fuerza bruta); las otras cuatro no se pueden comprobar desde fuera (contraseñas de la BD, credenciales de BD, cuenta deshabilitada y registro de eventos) y se documentan en el Informe de remediación.

6. Riesgo residual y recomendaciones

- **PHP 8.3 retirado del servidor:** el equipo eliminó los paquetes de Ubuntu que habían quedado desactivados (apt-get purge 'php8.3*' y autoremove). Para dejar constancia con salida de consola se recomienda ejecutar dpkg -l | grep php8.3 (no debe listar nada) y php -v | head -1 (PHP 8.5.12) y adjuntarlos.
- **Ventana de exposición del servidor (21/10 al 26/10/2026 18:20 UTC):** antes del cambio no se comprobó con el registro de cambios si el PHP 8.3 de Ubuntu ya traía el parche; la instancia no había aplicado actualizaciones («71 not upgraded»). Se recomienda revisar el registro de Apache en busca de caídas de procesos como indicio de intentos de explotación: sudo grep -i -E 'segfault|signal 11' /var/log/apache2/error.log*.
- **Mantenimiento del PPA:** Ondřej Surý avisa que ese repositorio se está fusionando con packages.sury.org/php; para Ubuntu «noble» y «jammy» sigue siendo utilizable, pero conviene vigilar la migración para seguir recibiendo parches.
- No usar PHP 7.4 ni 8.0 (sin soporte de seguridad). El README indica que la aplicación se probó en 7.4; conviene recomendar solo 8.3 o superior.
- Incorporar al proceso una revisión periódica de avisos de PHP y de las librerías de vendors/, que es lo que la fila V15 del informe de remediación dejaba como parcial.
- Aplicar las actualizaciones pendientes del sistema operativo de la instancia (sudo apt-get upgrade), fuera de la ventana de revisión.

7. Fuentes

- The PHP Foundation, «Today's PHP Security Release, and How We're Strengthening PHP Security» (21/10/2026): https://thephp.foundation/blog/2026/10/21/todays-php-security-release-and-how-were-strengthening-php-security/
- Sansec, «PHP2Shell: PHP RCE (CVE-2026-109618, CVE-2026-109619)»: https://sansec.io/research/php2shell
- PHP, descargas para Windows y listado de sumas SHA256: https://downloads.php.net/~windows/releases/
- Ubuntu Security, CVE-2026-109618 (versiones corregidas por la distribución): https://ubuntu.com/security/CVE-2026-109618
- Launchpad, PPA ppa:ondrej/php (paquetes php8.5 8.5.12 para jammy y noble): https://launchpad.net/~ondrej/+archive/ubuntu/php

- Informe de remediación de pnkSecurity v2.2 (docs/INFORME_REMEDIACION_pnkSecurity) y guía local deploy/aws/README.md (no publicada en GitHub).